

# ICT2212

## Ethical Hacking



### Lecture 0

A/Prof. Guo Huaqun (Linda) & A/Prof. Vivek Balachandran

# Our team

First half (week 1-6):

A/Prof. Guo Huaqun (Linda) (Module Lead)

[Huaqun.guo@singaporetech.edu.sg](mailto:Huaqun.guo@singaporetech.edu.sg)

Second half (week 8-13):

A/Prof. Vivek Balachandran (Module Co-Lead)

[vivek.b@SingaporeTech.edu.sg](mailto:vivek.b@SingaporeTech.edu.sg)



# General information

---

## **Lecture:**

Every Thursday 11am – 1pm

SIT Punggol Campus E2-02-14-Lectorial 10

## **Lab:**

Every Thursday 2:00 pm – 4:00 pm

SIT Punggol Campus E2-07-13

# Learning Outcomes

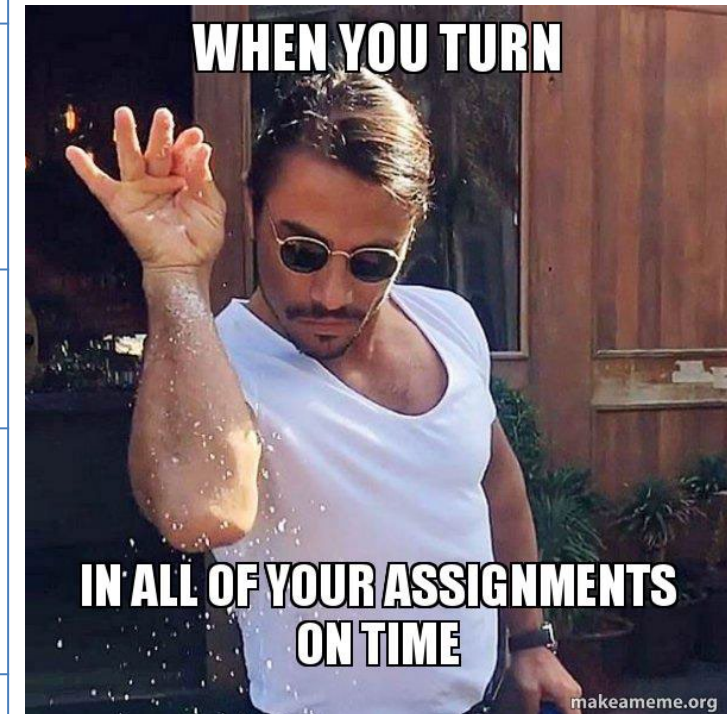
1. To distinguish between ethical and unethical hacking
2. To distinguish among the different ethical hacking phases
3. To select and apply suitable reconnaissance techniques and tools
4. To select and apply suitable sniffing, scanning and enumeration techniques and tools
5. To determine suitable target access gaining strategies
6. To determine suitable strategies to maintain access and cover tracks
7. To distinguish among the different types of Advanced Persistent Threat attacks

# Schedule (TBC)

| Week | Topics                                                                                                                                                                                                              | Lectures (hours) | Labs (hours) |
|------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------|--------------|
| 1    | Module Overview – Organization, Objectives and Scope<br>Introduction - Ethics and Legality Considerations; Basic Concepts and Terminologies; Physical and Operations Security; Pentesting Process and Methodologies | 2                | 2            |
| 2    | Reconnaissance – Footprinting Techniques and Tools; Social Engineering Techniques and Tools                                                                                                                         | 2                | 2            |
| 3    | Scanning and Enumeration                                                                                                                                                                                            | 2                | 2            |
| 4    | Sniffing – Techniques and Tools                                                                                                                                                                                     | 2                | 2            |
| 5    | System Hacking – Vulnerabilities; Attack Surface; Techniques and Tools                                                                                                                                              | 2                | 2            |
| 6    | Side Channel Attacks; Mid-Trimester Revision;<br>Quiz 1 (20%, in half of lecture time)<br>D1 Evaluation (10%)                                                                                                       | 2                | 2            |
| 7    | Intra-Trimestral Break                                                                                                                                                                                              |                  |              |
| 8    | Wireless Hacking – Vulnerabilities; Attack Surface; Techniques and Tools                                                                                                                                            | 2                | 2            |
| 9    | Web Hacking – Vulnerabilities; Attack Surface; Techniques and Tools                                                                                                                                                 | 2                | 2            |
| 10   | Web Hacking – Vulnerabilities; Attack Surface;<br>Quiz 2 (20%)                                                                                                                                                      | 2                | 2            |
| 11   | Maintaining Access;<br>Covering Tracks;                                                                                                                                                                             | 2                | 2            |
| 12   | Introduction to Advanced Persistent Threats<br>D2 Evaluation – Part 2 (15%)                                                                                                                                         | 2                | 2            |
| 13   | End-Trimester Revision;<br>CTF (35%)                                                                                                                                                                                | 2                | 2            |
|      | Total (hours)                                                                                                                                                                                                       | 24               | 24           |

# Assessment (TL;DR)

| Assessment Task                                                                                                                                                                                                                                                                                               | Due Date | Weighting |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|-----------|
| <p><b><u>Quiz 1</u></b></p> <p>This is an individual test. Students will be tested on what they have learnt in weeks 1 to 5 (Introduction, Reconnaissance, Scanning and Enumeration, Gain access).</p>                                                                                                        | Week 06  | 20%       |
| <p><b><u>Project Deliverable 1</u></b></p> <p>This is a team deliverable. Student teams will be assessed on this deliverable based on the scope of material taught in weeks 1 to 5. Appraisal will be according to specified rubrics covering both team and member performance and contribution.</p>          | Week 06  | 10%       |
| <p><b><u>Quiz 2</u></b></p> <p>This is an individual test. Students will be tested on what they have learnt in weeks 7 to 9.</p>                                                                                                                                                                              | Week 10  | 20%       |
| <p><b><u>Project Deliverable 2</u></b></p> <p>This is a team deliverable. Student teams will be assessed on this deliverable based on the scope of material taught in weeks 4 to 5, 8 to 11. Appraisal will be according to specified rubrics covering both team and member performance and contribution.</p> | Week 12  | 15%       |
| <p><b><u>Capture the flag (CTF)</u></b></p> <p>This is an individual practical test. Students will be tested on what they have learnt in weeks 1-11.</p>                                                                                                                                                      | Week 13  | 35%       |



# Course Deliverables – Team as Defender

## Team Composition:

- Teams of **6 members**
- Members of each team have been assigned (see xSiTe)
- All members have access to e-learning labs
- Each team will act as **defender** then **attacker**

## Defender Process (Details in Lab Manual):

- As a defender, each team sets up a **hardened vulnerable system**
- Defender will demonstrate **successful reconnaissance, scanning and enumeration, gaining of access on own**
- Defender will document and submit **R1 report including software source codes** by **Week 7**
- IP address of defending team's system will be assigned confidentially



# Course Deliverables – Team as Attacker

## Attacker Process:

- As an attacker, each team will try to conduct successful reconnaissance, scanning and enumeration, and gaining of access
- Each team's targets will be any of these VMs (excluding own system) – randomly assigned **1 target**
- Attacker will demo reconnaissance, scanning and enumeration by **week 8-10**
- Attacker will also demo gaining of access by **week 9-12**
- All teams must also propose and document strategy to maintain access and cover tracks, and submit **R2 report** by **week 12**

**You may use social engineering**

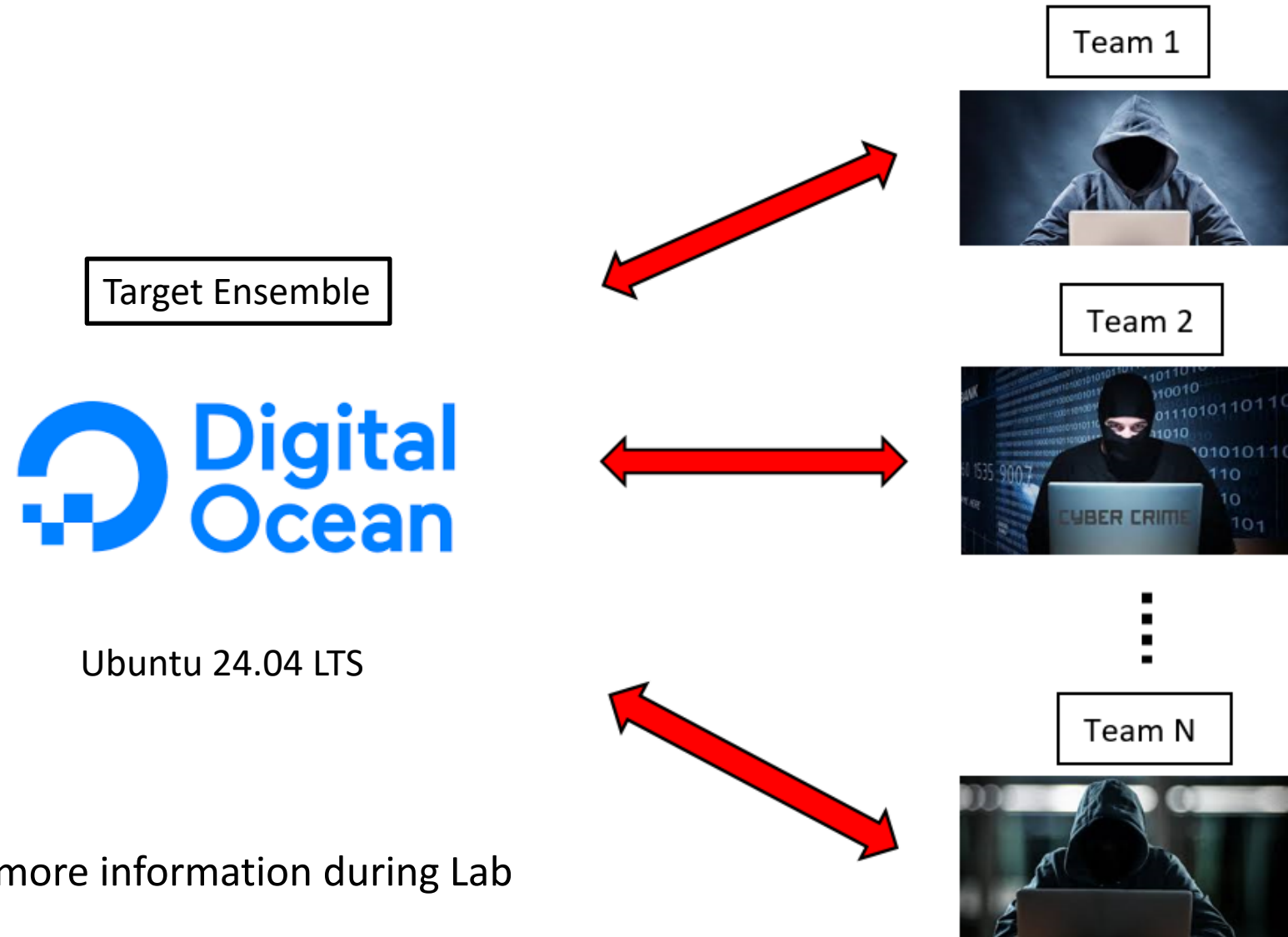
**You must NOT access targets before week 7**

**You must NOT broadcast your assigned IP addresses**

**You must NOT share your exploit approaches – marks divided**



# Attacking Scenario Objective



We will provide more information during Lab

# Deliverables Schedule and Marks

| Week                    | 1                    | 2 | 3 | 4                              | 5 | 6 | 7  | 8                                                              | 9 | 10 | 11                                             | 12 | 13 | 14 | CA deliverables                                                                              |
|-------------------------|----------------------|---|---|--------------------------------|---|---|----|----------------------------------------------------------------|---|----|------------------------------------------------|----|----|----|----------------------------------------------------------------------------------------------|
| Week 1 - 6<br>Defender  | Setup the own server |   |   |                                |   |   |    |                                                                |   |    |                                                |    |    |    |                                                                                              |
|                         |                      |   |   | Harden and Demo the own server |   |   |    |                                                                |   |    |                                                |    |    |    |                                                                                              |
|                         |                      |   |   |                                |   |   | R1 |                                                                |   |    |                                                |    |    |    | R1: Server Report due Week 7                                                                 |
| Week 8 - 13<br>Attacker |                      |   |   |                                |   |   |    | Foot-print, Scan and Enumerate other servers (target) and Demo |   |    | Gain access to other servers (target) and Demo |    |    |    | Demo foot-printing, scanning and enumeration of target(s)<br>Demo access gained to target(s) |
|                         |                      |   |   |                                |   |   |    |                                                                |   |    |                                                | R2 |    |    | R2: Penetration Testing Report due Week 12                                                   |
|                         |                      |   |   |                                |   |   |    |                                                                |   |    |                                                |    | PR |    | PR: Peer review due Week 13                                                                  |

# E-Learning and Team Contribution

## E-Learning Labs

- Reconnaissance Familiarization Labs – more for those with no/minimal background in IS
- Scanning and Enumeration Familiarization Lab
- 2nd half labs

## Team Contribution

- Project team – mixed capability
- Each team must specify and manage their own allocation of roles and duties
- Each team member is expected to contribute to the best of his / her ability (peer reviews)

# Assessments

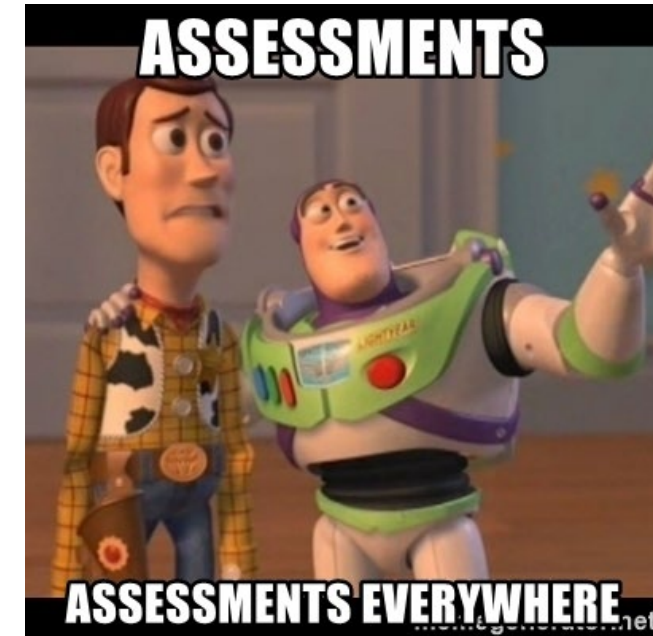
In short:

- Project: 25%
- Quiz: 40%
- CTF: 35%

In another way:

- Quizzes: Q1 (20%) + Q2 (20%) = 40% (Individual)
- Assignment Deliverables: D1 (10%) + D2(15%) = 25% (Team)\*
- CTF: 35% (Individual)

\*Peer review – member contribution and teamwork



# Required and Recommended Resources

## Required Resources

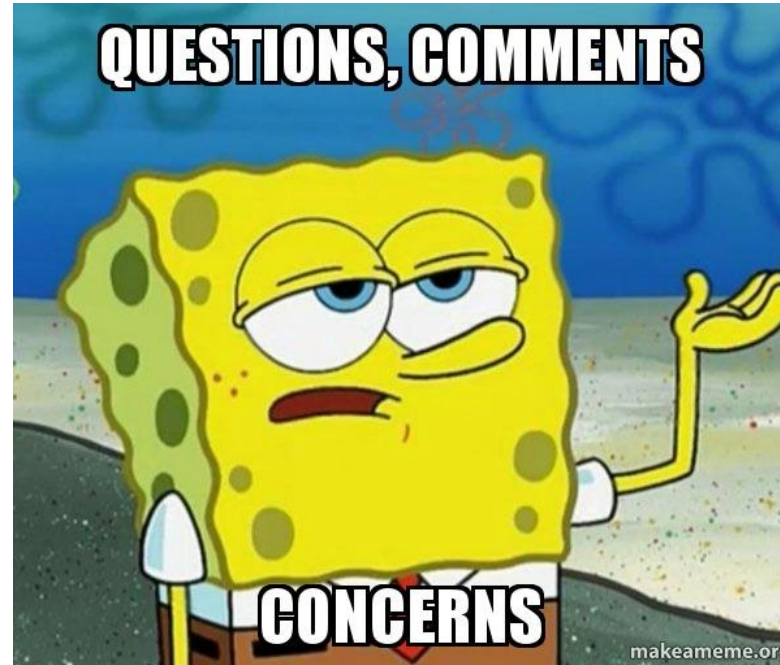
- <https://cve.mitre.org/> (Common Vulnerabilities and Exposures)
- <https://nvd.nist.gov/> (National Vulnerability Database)

## Recommended Resources

- Gray Hat Hacking The Ethical Hacker's Handbook by Daniel Regalado, Shon Harris, Allen Harper, Chris Eagle, Jonathan Ness, Branko Spasojevic, Ryan Linn, and Stephen Sims, 4th Edition, McGraw-Hill Osborne Media, 2014.
- Hacking with Kali by James Broad and Andrew Bindner, Syngress, 2013
- Anti-Hacker Toolkit by Mike Shema, 4th Edition, McGraw-Hill Osborne Media, 2014.

# How to get an A in this module





**QUESTIONS OR COMMENTS?**



# Background of Ethical Hacking

# What is Ethical Hacking?

- Let's break down into:
  - What is ethical?
  - What is hacking?



# What is Ethic?

## ethical

adjective • **UK**  /'eθ.ɪ.kəl/ **US**  /'eθ.ɪ.kəl/

★ **C2** relating to beliefs about what is morally right and wrong:

*ethical and legal issues*

*the ethical dilemmas surrounding genetic research*

★ **C2** morally right:

*ethical practice/trading*

*a medical procedure that most people believe to be ethical*

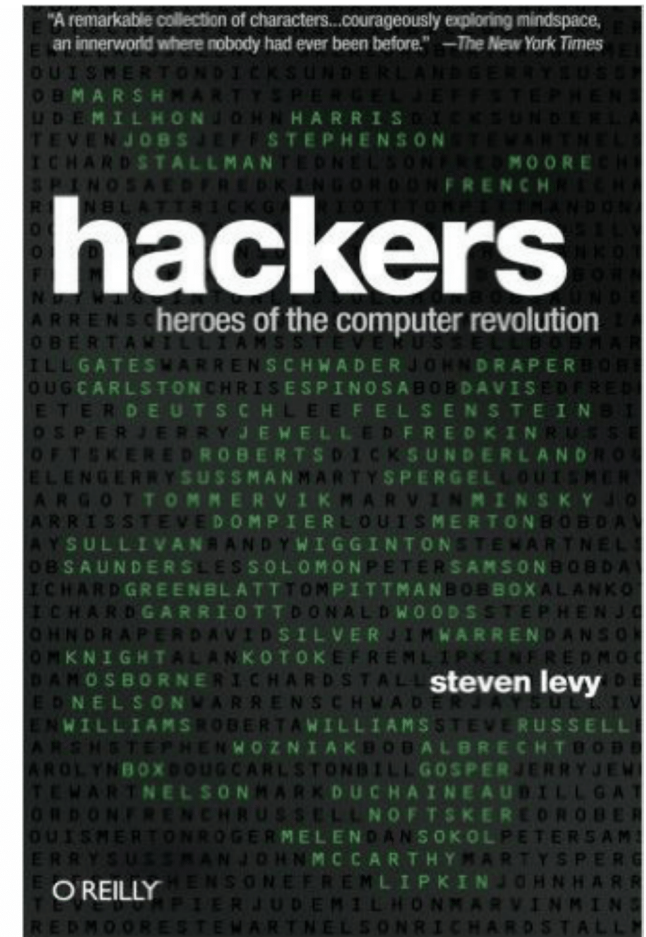
- INF1007 Ethics and Professional Conducts

# What is Ethic?

*Hackers: Heroes of the Computer Revolution* by Steven Levy.

- Access to computers should be unlimited and total.
- All information should be free.
- Mistrust authority—promote decentralization.
- Hackers should be judged by their hacking, not bogus criteria such as degrees, age, race or position.
- You can create art and beauty on a computer.
- Computers can change your life for the better.

The above is from the Hacker's Point of View



# What is Hacking?

Process of breaking into systems for:

- Personal, Military or Professional Goals
- Malicious Intent – Causing severe damage to reputation and assets, steal information, exploit weakness
- Professional Intent – Finding weaknesses (vulnerabilities) and improving security posture



**My intentions are professional; can I start hacking?**



# Computer Misuse Incident



Syndicated online credit card fraud

<https://www.straitstimes.com/singapore/courts-crime/2-men-arrested-over-10k-worth-of-illegal-transactions-from-stolen-credit-card>

A laptop, five mobile phones, two thumbdrives and about \$630 in cash were seized as case exhibits. PHOTO: SINGAPORE POLICE FORCE

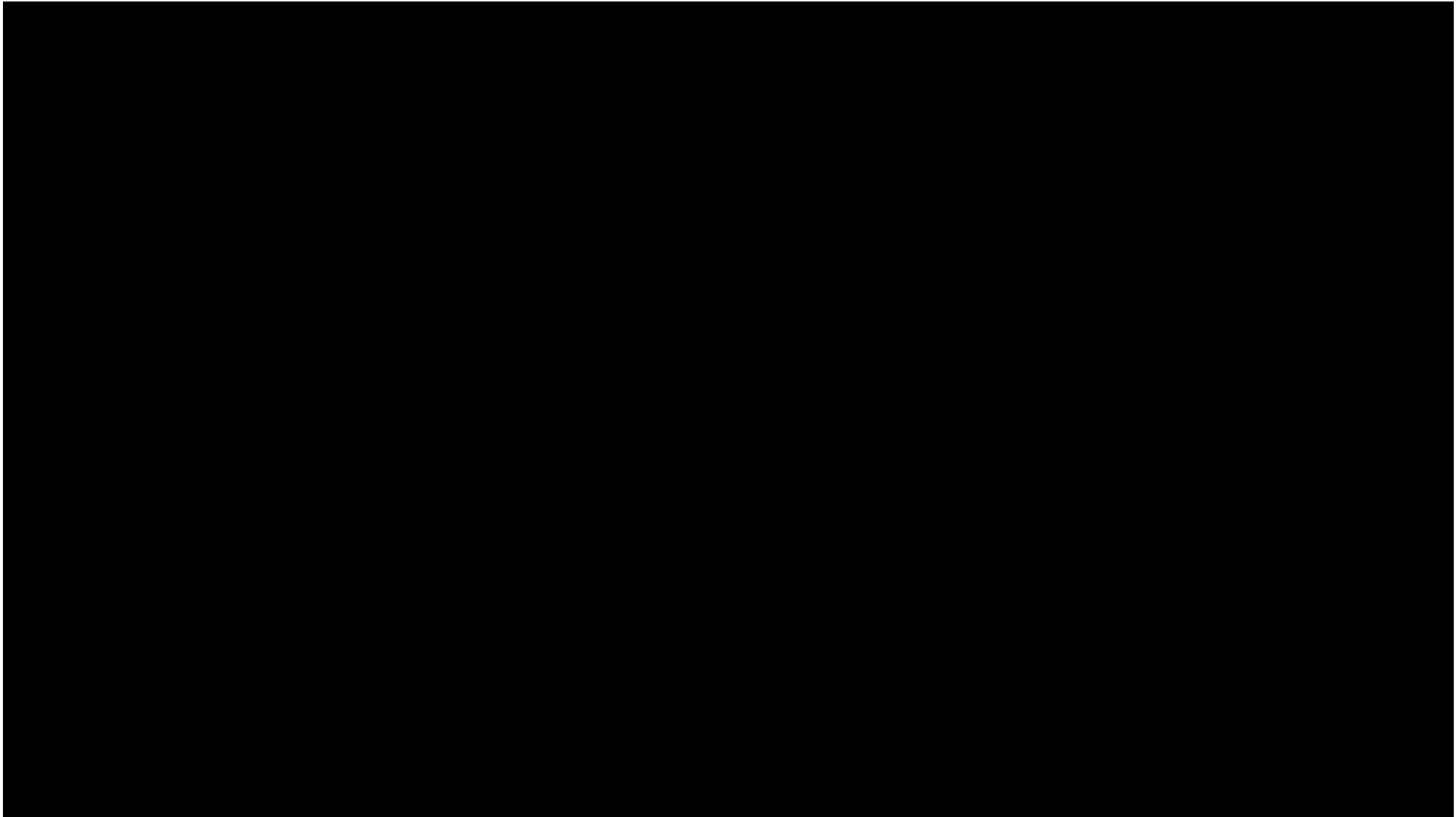
# Computer Misuse Incident



Using stolen debit and credit card details to commit payment frauds

[SPF | Three Members Of A Transnational Scam Syndicate Arrested For Their Suspected Involvements In Committing Islandwide Payment Frauds](#)

# Computer Misuse Example





# Computer Misuse and Cyber Security Act

## Offences (Chapter 50A Part II - Offences):

- Unauthorized access to computer material
- Access with intent to commit or facilitate commission of offence
- Unauthorized modification of computer material
- Unauthorized use or interception of computer service
- Unauthorized obstruction of use of computer
- Unauthorized disclosure of use access code
- Enhanced punishment for offences involving protected computers
- Abetments and attempts punishable as offences

**WHAT IS THE KEY WORD HERE?**

# Whose Laws Rule the Web?

## When Digital Actions Cross Borders:

- Laws vary from country to country
- Corporations that do business in multiple countries must comply with the laws of all the countries involved
- Someone whose actions are legal in their own country may face prosecution in another country where their actions are illegal (e.g. child pornography)

## Areas in which national laws differ:

- Content control / censorship
- Intellectual Property
- Hacking / Viruses (eg. ILoveYou virus, Ransomware wannacry)
- Privacy ... (eg. Europe's privacy laws much stricter than US)

# International Collaborations

## Convention on Cybercrime:

- <http://conventions.coe.int/Treaty/EN/Treaties/Html/185.htm>

**International agreement** to foster international cooperation among law enforcement agencies of different countries in fighting:

- Offences against CIA of computer data and systems
- Copyright-related offences
- Computer-related offences – e.g. online fraud
- Content-related offences – e.g. child pornography

**Set common standards or ways to resolve international cases**

**Singapore's MOUs – France, India, Netherlands, UK, US, Australia, etc**

# Ethics in Information Security

Ethics are rules that we fall back on when the law does not pertain to a particular situation or does not provide clear direction for a particular circumstance:

- Protect society, commonwealth and the infrastructure
- Act honourably, honestly, justly, responsibly, and legally
- Provide diligent and competent service
- Advance and protect the profession

(ISC2 Code of Ethics) <https://www.isc2.org/Ethics#/>

# Hacker ethics...?

1. Access to computers—and anything which might teach you something about the way the world works—should be unlimited and total. Always yield to the Hands-On Imperative!
2. All information should be free
3. Mistrust authority—promote decentralization
4. Hackers should be judged by their hacking, not bogus criteria such as degrees, age, race, sex, or position
5. You can create art and beauty on a computer
6. Computers can change your life for the better



# What is a Hacker?



## What is a Hacker?

Anyone who breaks into (or attempts to) computer systems

# Types of Hackers



## White Hat:

- The guy authorised to conduct hacking
- The computer security professional who uses skills to help
- Hacking as job to help secure systems and provide insight into policies and procedures

## Black Hat:

- The guy who hacks without authorisation
- The computer security expert who uses skills to steal, damage and destroy
- Hacking for personal gain or motive



# Types of Hackers



## Gray Hat:

- Sometimes good guy, sometimes bad
- The skilled hacker whose methods may cross legal and ethical boundaries
- May transfer vulnerability knowledge to either systems owner or black hat

# More color...



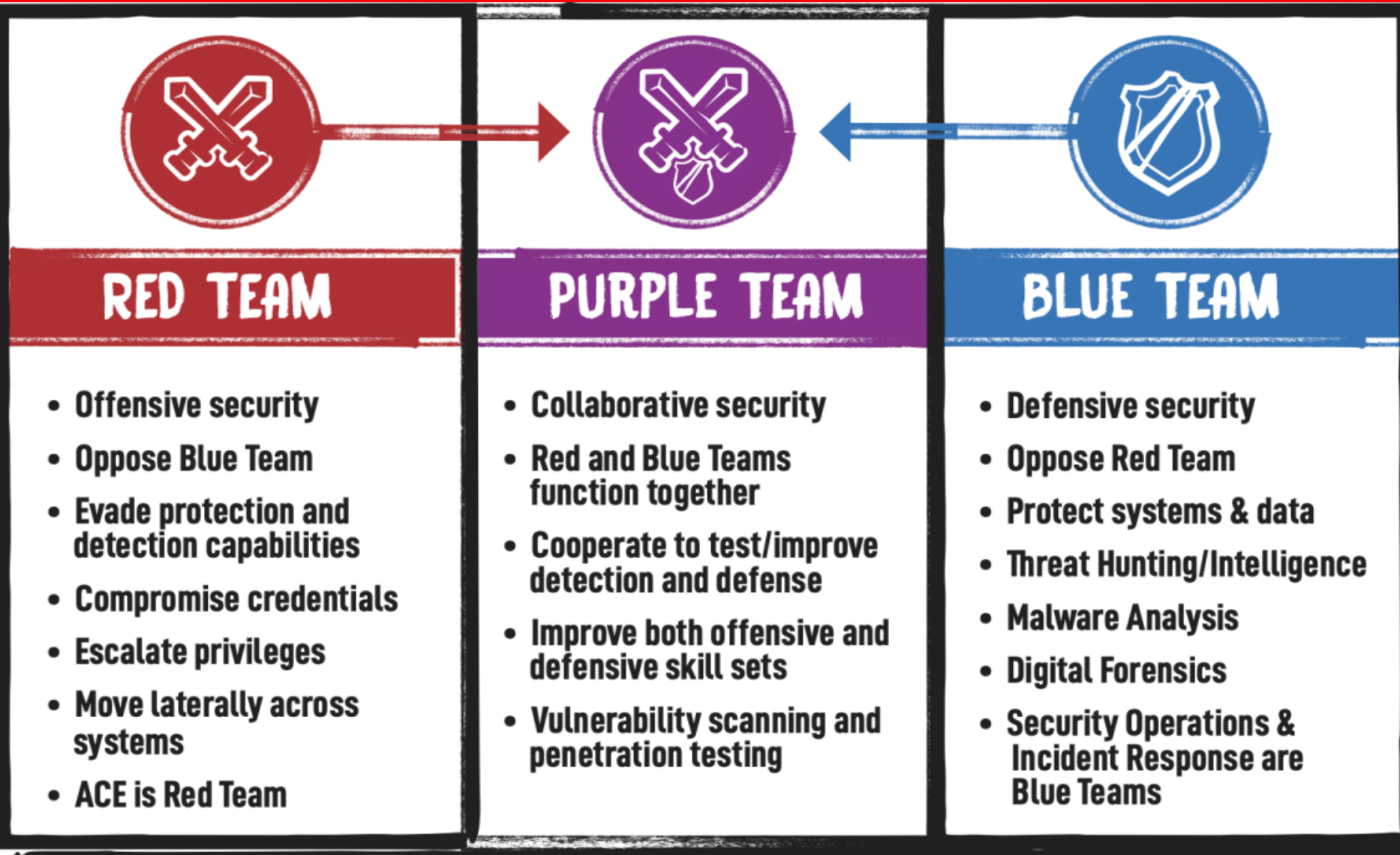
What Hat does an Ethical Hacker wear?

# Other Categories

- A **script kiddie** is a derogatory term for inexperienced hackers who use scripts and programs developed by others, without knowing how they work, for the purpose of compromising computer accounts and files, or for launching attacks on whole computer systems.
- A **system administrator**, abbreviated sysadmin, designates a role responsible for running information systems or some aspect of them. They often deal with the setup and maintenance of computers and networks.

**Can all Hackers be Easily Categorized?**

# Hacker Team



Why not black team and white team?

# Learn Ethical Hacking

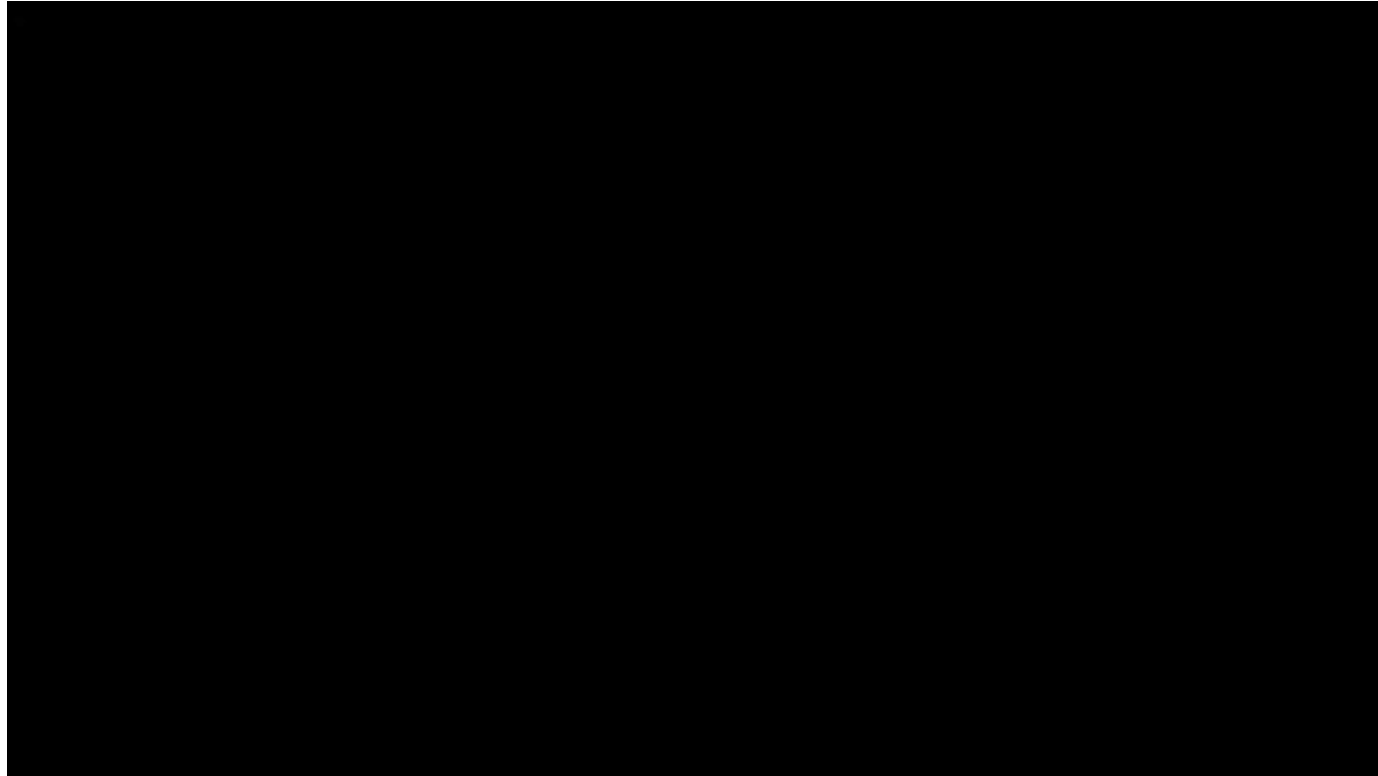


The overall goals as an ethical hacker should be as follows:

- Hack your systems in a **non-destructive** fashion.
- Enumerate vulnerabilities and, if necessary, prove to upper management that vulnerabilities exist.
- Apply results to remove vulnerabilities and better secure your systems.

# **CAMPAIGNING VIA THE INTERNET**

# Internet Campaigning Overview



- Forum for political expression – the ends justify the means
- In extreme cases, may be used to cause widespread unrest and social disruption
- **Hactivism, Cyberterrorism and Information Warfare**



# Hacktivism



- Formed by combining “hack” with “activism”
- **Hacktivism** is the act of hacking into a web site or computer system to communicate a politically or socially motivated message
- Unlike a malicious hacker, who may disrupt a system for financial gain or to cause harm, the **hacktivist** performs the same kinds of disruptive actions (e.g. a DoS attack) to draw attention to a cause



- Terrorist groups use Internet to recruit, spread propaganda, and plan attacks
- Cyber-warfare conducted with Advanced Persistent Threats (APTs)
- In 2015, visitors to the MalaysiaAirlines.com saw the above which lasted for several hours. Airlines ticket booking and other services were unavailable.



## New Zealand banks, post office hit by outages in apparent cyber attack

*The country's Computer Emergency Response Team (CERT) said it was aware of a DDoS (distributed denial of service) attack targeting a number of organisations in the country.*

Reuters • September 08, 2021, 07:44 IST



## US pipeline hacking signals growing cyber-security risk for energy system



17 Mar 2018 08:23AM  
(Updated: 22 Mar 2018 10:22AM)



Bookmark



Wdfload Trojan –  
injects adverts  
into search results  
and websites

## 'Some indicators' Singapore was target of information warfare recently, says academic



- Select Committee on Deliberate Online Falsehoods in a private session
- False news could be first line of attack on nation – Internet Trolls



# An Internet Troll



- Person or persons who deliberately post provocative or abusive messages via the Internet to start disputes and/or sow discord
- On a larger scale – initiates disinformation campaigns to disrupt social fabric and cause unrest
- <https://www.straitstimes.com/singapore/how-online-trolls-divided-societies>

What are the criteria to be considered a famous hacker?

# **FAMOUS HACKERS**

# Some Famous Hackers



**Ian Murphy**



**Kevin Mitnick**



**Onel de Guzman**



**Jonathan James**



**John Draper**



**Robert Morris**



# Kevin Mitnick

- Known as world's most famous hacker
- Started as a **phreaker** (person who hacks into telecommunication systems)
  - Inspired by John Draper (Captain Crunch)
- He took control of a local telephone switching office with a modem and PC
  - Took control of Pacific Bell network
  - Gained access into a Pentagon computer
- CEO of security firm:  
<https://www.mitnicksecurity.com/>
- Bestselling Books by Kevin Mitnick:  
<https://www.mitnicksecurity.com/bestselling-books-by-kevin-mitnick>



# John Draper (aka Captain Crunch)

- He was introduced to a toy whistle (in a box of Cap'n Crunch cereal) that produced a 2600 hz tone which was same frequency used by ATT's long distance network
- World's first phreaker - developed the 'blue box' tone generator based on experiments with the whistle and used it to hack a telephone line and get free phone calls
- Stephen Wozniak, a student at Berkeley, manufactured and sold the blue box to make money to finance the first Apple computer
- Founder of ShopIP which sells the CrunchBox firewall system (endorsed by Steve Wozniak)
- From 2005 to 2010, Draper was the Chief Technical Officer (CTO) for media delivery company En2go



# Robert Morris, Jr.

- Created Morris worm in 1988
- Morris worm exploited vulnerabilities in Unix sendmail, fingerd, rsh/rexec and weak passwords
- CERT/CC was created in response to the Morris worm
- Currently a professor of Computer Science and Engineering at MIT

## Morris Worm Code:



The screenshot shows the Visual Studio IDE with the following details:

- Menu Bar:** File, Edit, View, Search, Project, Build, Debug, Tools, Help.
- Toolbar:** Standard Visual Studio toolbar with icons for file operations, building, and debugging.
- Project Explorer:** Shows a project named 'worm' with a file 'worm.cpp'.
- Code Editor:** Displays the source code of 'worm.cpp'. The code includes various system headers and defines a function to get the IP address of a host.
 

```

1  /* worm.cpp */
2
3  #include "worm.h"
4  #include <stdio.h>
5  #include <stdlib.h>
6  #include <string.h>
7  #include <sys/types.h>
8  #include <sys/time.h>
9  #include <sys/resource.h>
10 #include <sys/socket.h>
11 #include <sys/fcntl.h>
12 #include <sys/stat.h>
13 #include <netinet/in.h>
14 #include <net/if.h>
15 #include <arpa/inet.h>
16
17 extern error;
18 extern char *malloc();
19
20 int plessequit; /* See worm.h */
21 int nobjects = 0;
22 int nextw;
23 char *mail_auth;
24
25 object objects[69]; /* See worm.h */
26
27 object *getobjectbyname();
28
29 char *XS();
30
31 main(argc, argv) /* 0x2000 */
32 {
33     int argc;
34     char **argv;
35
36     int i, l, pid_arg, j, cur_arg, unused;
37     long key;
38     struct rlimit rl; /* ~256 */
39
40     rl = 0; /* Unused */
41 }

```
- Output Window:** Shows 'Logs & Others' with tabs for CodeBlocks, Search results, C++ Compiler, Build log, Build messages, C++ Check, C++ Check messages, Cscope, Debugger, DoryBlocks, Closed files list, and Thread search. A message states: 'Create new parser for project "worm" Project "worm" parsing stage done'.

# Hackers' Language

1 -> i or L

3 -> e

4 -> a or A

7 -> t

9 -> g

0 -> o

\$ -> s

l -> 1 or !

|\| -> n

|\V| -> m

5 -> S

Z -> 2

f -> ph

K -> |<

X -> ><

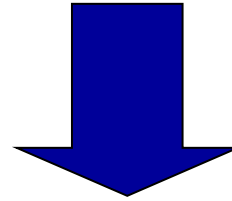
D -> |)

1337 Speak – invented for coded communications; hiding websites, newsgroups etc. to avoid detection by search filters; create stronger passwords

# Translation Examples

- Example 1:

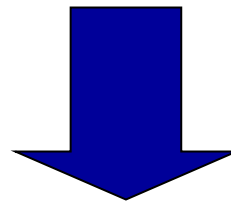
- 1 d1d n0t h4ck th1s p4g3, 1t w4s l1k3 th1s wh3n 1 h4ck3d 1n



- I did not hack this page, it was like this when I hacked in

- Example 2:

- Hacking is Good



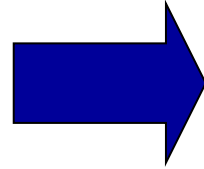
- H4ck||\|g 1\$ 900d

Replacing a certain percentage of letters in a word with non-alphabetic symbols

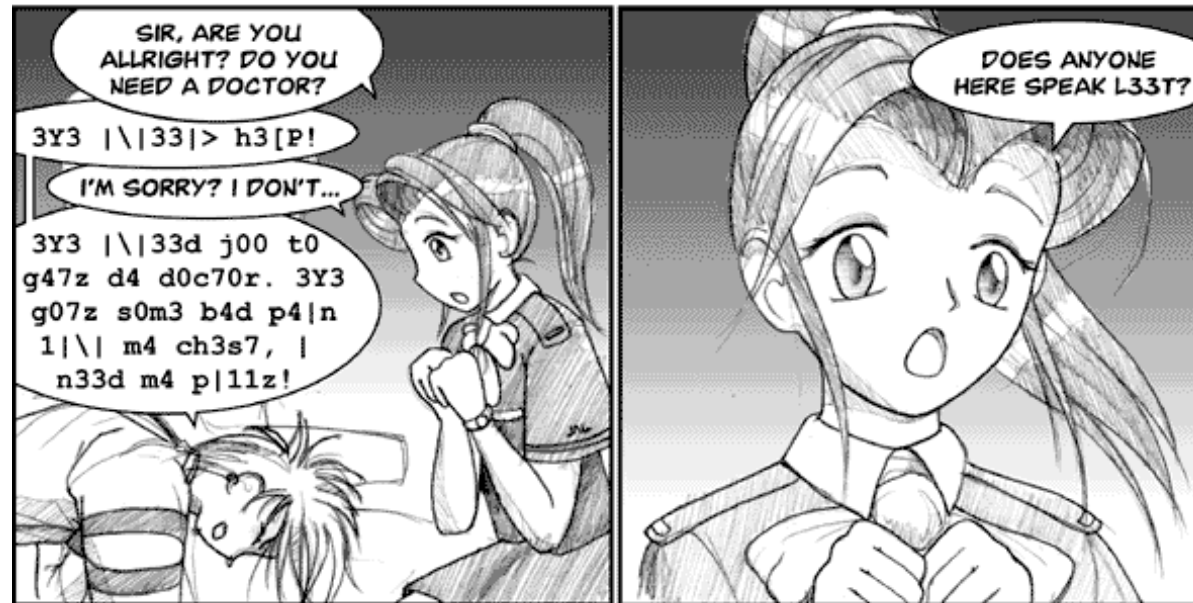
# Try Translating This:

- Example 3:

➤ 3Y3 |\| 33|> h3[P!



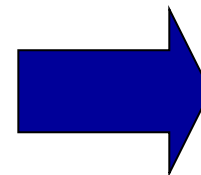
**I NEED HELP!**



© 2000 Fred Gallagher, all rights reserved.

- Example 4:

➤ 3Y3 |\| 33|> j00 t0 g47z d4 d0c70r.



**I NEED YOU TO GET THE DOCTOR.**



# Trying Reading These:

## 10% Leetification

Fourscore and seven years ago our fathers brought forth on this continent a new nation, conceived in liberty and dedicated to the proposition that all men are created equal.

## 50% Leetification

f0ur\$(0r3 4n? \$3v3n ¥34r\$ 490 0ur f47h3r\$ br0μ9h7 f0r7h 0n 7h1\$ (0n71n3n7 4 n3w n4710n, (0n(31v3? 1n £1b3r7¥ 4n? ?3?1(473? 70 7h3 pr0p0\$1710n 7h47 4££ m3n 4r3 (r3473? 3qμ4£.

## 100% Leetification

f0μ®\$(0®3 4|\|? \$3V3|\| ¥34®\$ 490 0μ® f47|-|3®\$ β®0μ9|-|7 f0®7|-| 0\| 7|-|1\$ (0\|71\|3\|7 4 \|3VV \|4710\|, (0\|(31V3? 1\| £1β3®7¥ 4|\|? ?3?1(473? 70 7|-|3 p®0p0\$1710\| 7|-|47 4££ |V|3\| 4®3 (®3473? 31μ4£.

# Try these links:

<http://1337.me/>

<https://www.albinoblacksheep.com/text/leet>

<https://md5decrypt.net/en/Leet-translator/#results>

<http://www.robertecker.com/hp/research/leet-converter.php?lang=en>

# Summary

- Module Overview
  - Learning Expectations and Objectives
  - Course Topics and Assessment Components
  - Lab Organization
- Overview of Hacking and Legality Issues
- What is a Hacker?
  - Types - Hat Colours
  - Internet Campaigners – hacktivist, cyber terrorist, info warfare protagonists, internet trolls
  - Famous Hackers – lessons learnt from exploits
- Leet Speak
  - Used for coded communications
  - Used to evade internet search filters (hide websites, newsgroups etc.)
  - Used to form stronger passwords

**Next Lecture – Introduction to Ethical Hacking**

# My Advice



Not about  
marks, but skills



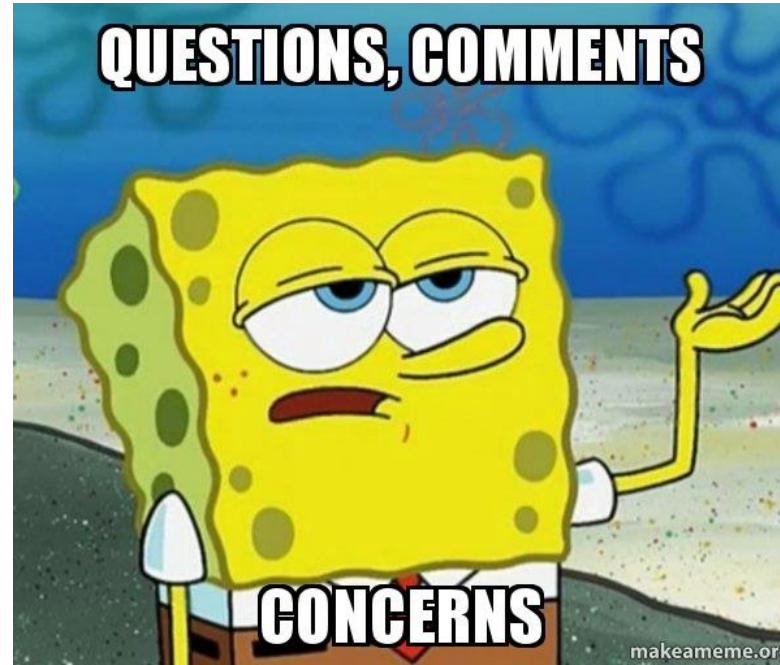
Enjoy yourself in  
this module



Build relations &  
help each other  
to grow  
together



Capstone Projects,  
Publications,  
Master of Engineering,  
Doctor of Engineering  
Contact A/Prof. **Guo  
Huaqun (Linda)**



**QUESTIONS OR COMMENTS?**